Hospitaly – Launch-blocking security patch (do before real guests)

Paste into Antigravity. Small, focused patch. Do not change UI except where stated. Deploy rules and app together, then run the probes at the bottom.
Verified live (29 Oct, no login, plain REST calls with the public web API key):

- `GET rooms/room_rocks_101` and `rooms/room_rocks_103` → **200**, returning `currentGuestName`, `guestTitle`, `guestPhone`, `guestCheckOutDate`, `activeStayId`. Room IDs are predictable (`room_rocks_101…105`) and visible in the public GitHub repo. **Anyone on the internet can read current guests' names and phone numbers.**
- `GET properties/prop_rocks_lusaka` → 200 incl. `wifiPassword`, `contactEmail`, `suspendedBy` (acceptable for Wi-Fi, but remove email/suspendedBy from public view).
- Lists of users/requests/rooms/stays → 403 (good).
  From reading `firestore.rules`:
- Because `activeStayId` is public on the room, anyone can **create requests for any occupied house** (no login needed) → prank/spam risk.
- The "guest update" branch of `requests` has **no identity check** → anyone who learns a request ID can cancel it or edit its description/priority/delivery preference.
- `activity` allows create by anyone when the property is active → fake audit-log entries.
- `isKnownFounderEmail()` grants founder to `founder.pilot@hospitaly.app` and `nathanielmazaba@gmail.com` by email alone, without `email_verified`. If Firebase Auth sign-up is enabled, anyone could register `founder.pilot@hospitaly.app` and become founder.

1. Guest access must be bound to the QR token (secret), not to guessable IDs

1. **Regenerate all QR tokens** as long random strings: `crypto.getRandomValues` → 20+ chars base62 (e.g. `rk_7fK2pQ9xLmT4vWz8aB3c`). Keep the house name out of the token. Old tokens → `status: 'revoked'`. (Cards must be reprinted — that's fine before launch.)
2. Store the guest-facing data a guest needs on the **token doc**, not the room doc: `qrCodes/{token}`: `propertyId, roomId, status, houseName, houseType, imageId, wifiName, wifiPassword, guestGreeting ("Ms Princess Mazaba"), activeStayId`. Update it on check-in / check-out / edit house (same write batch as the room/stay).
3. Guest app loads **only** `qrCodes/{token}` (+ property public fields, media, house guide). It must not read `rooms/*` or `stays/*`.
4. Rules:

- `rooms/{id}`: `get/list` only for founder or staff of that property. No public read.
- `stays/{id}`: read only for founder or staff of that property (remove `allow get: if true`).

- `qrCodes/{token}`: `get` if `resource.data.status == 'active'`; **no** `list` for non-staff.
- `properties/{id}`: public `get` must not expose `contactEmail`, `suspendedBy` → move them to `properties/{id}/private/settings` (staff/founder only).

5. **Requests from guests** must carry the token: rule requires `get(/databases/$(database)/documents/qrCodes/$(request.resource.data.qrToken)).data.roomId == request.resource.data.roomId`, `...data.activeStayId == request.resource.data.stayId`, token `status == 'active'`, property active. Store `qrToken` on the request (staff never see it in the UI).
6. **Guest read/update of requests** (cancel, delivery preference, My Requests list) must also prove the token: query `where('qrToken','==',token) && where('stayId','==',stayId)`, rule `resource.data.qrToken == <token from query>` is not possible directly → use **Firebase Anonymous Auth** instead:
   - Enable Anonymous sign-in. On QR load: `signInAnonymously()`, then create `guestSessions/{uid}` with `{ token, roomId, stayId, createdAt }` — rule: allowed only if `qrCodes/{token}` is active and its `roomId/activeStayId` match.
   - `requests` create/read/update for guests: `request.auth.uid` must have a `guestSessions/{uid}` doc whose `roomId` and `stayId` match the request; on create set `guestUid = request.auth.uid`. Guest update only if `resource.data.guestUid == request.auth.uid`.
   - On check-out, the stay changes → old guest sessions stop matching automatically.
7. Rate-limit guests: max 10 open requests per stay (rule: count via a counter doc `stays/{id}/meta/counter` incremented in the same batch, or enforce in a client check + manager "Block this QR" button that sets token `status: 'revoked'`).

2. Founder / roles

- Remove `isKnownFounderEmail()` entirely. Founder = `users/{uid}.role == 'founder'` (and `active == true`) only. Also require `request.auth.token.email_verified == true` for any staff/manager/founder rule.
- Remove the `request.auth.token.role` custom-claim shortcut unless claims are set by an Admin script (they aren't).

3. Activity log

- `activity` create only `isUserActive()` (signed-in staff/manager/founder). Guests never write activity directly.

4. Repo & data hygiene

- Remove real Wi-Fi passwords and phone numbers from `docs/go/REPORT.md`, seeds and tests; use placeholders.
- Delete the old built `dist/` from git if committed; `dist/` must stay ignored.
- `.env.example` only placeholders.

5. Probes (add as `tests/security/probe.spec.ts`, run against the deployed preview, no login)

- [ ] `GET rooms/<any id>` → 403
- [ ] `GET stays/<any id>` → 403
- [ ] `GET properties/prop_rocks_lusaka` → 200 **without** `contactEmail`, `suspendedBy`
- [ ] `GET qrCodes/<old token>` → revoked/403; `GET qrCodes/<new token>` → 200 with guest fields only
- [ ] Unauthenticated `POST requests` → 403
- [ ] Anonymous user with no guest session `POST requests` → 403
- [ ] Anonymous guest of Chisenga cannot read/cancel a Bobo request → 403
- [ ] Unauthenticated `POST activity` → 403
- [ ] Newly registered email account with no `users` doc → cannot read anything

Then re-run the full e2e suite (guest round trip must still work).